ICare Fresh ZAP Retest - 2aa4b8f

Group 113. Isolated synthetic fixtures only. Passive scan and targeted manual HTTP verification. No spider or active scan.

Site: http://host.docker.internal:4021

Generated on Fri, 16 Oct 2026 13:31:48

ZAP Version: 2.17.0

ZAP by Checkmarx

Summary of Alerts

Risk Level	Number of Alerts
High	1
Medium	3
Low	1
Informational	1
False Positives:	0

Insights

Level	Reason	Site	Description	Statistic
Low	Warning		ZAP errors logged - see the zap.log file for details	1
Low	Warning		ZAP warnings logged - see the zap.log file for details	3
Info	Informational	http://host.docker.internal:4021	Percentage of responses with status code 2xx	40 %
Info	Informational	http://host.docker.internal:4021	Percentage of responses with status code 4xx	60 %
Info	Informational		Percentage of endpoints with content	12 %

		http://host.docker.internal:4021	type application/javascript	
Info	Informational	http://host.docker.internal:4021	Percentage of endpoints with content type application/json	76 %
Info	Informational	http://host.docker.internal:4021	Percentage of endpoints with content type text/css	2 %
Info	Informational	http://host.docker.internal:4021	Percentage of endpoints with content type text/html	7 %
Info	Informational	http://host.docker.internal:4021	Percentage of endpoints with method GET	48 %
Info	Informational	http://host.docker.internal:4021	Percentage of endpoints with method POST	30 %
Info	Informational	http://host.docker.internal:4021	Percentage of endpoints with method PUT	20 %
Info	Informational	http://host.docker.internal:4021	Count of total endpoints	39
Info	Informational	http://host.docker.internal:4021	Percentage of slow responses	8 %

Alerts

Name	Risk Level	Number of Instances
Vulnerable JS Library	High	1
CSP: Wildcard Directive	Medium	2

CSP: style-src unsafe-inline	Medium	3
Vulnerable JS Library	Medium	1
Timestamp Disclosure - Unix	Low	Systemic
Modern Web Application	Informational	3

Alert Detail

High	Vulnerable JS Library
Description	The identified library appears to be vulnerable.
URL	http://host.docker.internal:4021/static/js/main.ba8f17b4.js
Node Name	http://host.docker.internal:4021/static/js/main.ba8f17b4.js
Method	GET
Attack	
Evidence	return"[Axios v1.7.7] Transitional
	The identified library axios, version 1.7.7 is vulnerable. CVE-2025-62718 CVE-2026-101902 CVE-2025-27152 CVE-2026-101904 CVE-2025-58754 CVE-2026-42041 CVE-2026-42040 CVE-2026-101908 CVE-2026-67317 CVE-2026-42039 CVE-2026-67319 CVE-2026-42034 CVE-2026-40175 CVE-2026-42033 CVE-2026-67312 CVE-2026-42038 CVE-2026-44495 CVE-2026-42037 CVE-2026-44496 CVE-2026-67313 CVE-2026-42036

Other Info	CVE-2026-67316 CVE-2026-42035 CVE-2026-44494 CVE-2026-44490 CVE-2026-25639 CVE-2026-44488 CVE-2026-42044 CVE-2026-42264 CVE-2026-42043 CVE-2026-42042 CVE-2026-44486 CVE-2026-44487 https://github.com/axios/axios/security/advisories/GHSA-42h9-826w-cgv3 https://github.com/axios/axios/security/advisories/GHSA-hfxv-24rg-xrqf https://github.com/axios/axios/commit/d19040bda7a8be2f82c3c6e1a5bc03917daee39a https://github.com/axios/axios/issues/6463 https://github.com/axios/axios/security/advisories/GHSA-vf2m-468p-8v99 https://github.com/axios/axios/security/advisories/GHSA-xhjh-pmcv-23jw https://github.com/axios/axios/security/advisories/GHSA-p92q-9vqr-4j8v https://github.com/axios/axios/commit/28c721588c7a77e7503d0a434e016f852c597b57 https://github.com/axios/axios/pull/10661 https://github.com/axios/axios/pull/10660 https://github.com/axios/axios/commit/fb3befb6daac6cad26b2e54094d0f2d9e47f24df https://github.com/axios/axios/releases/tag/v1.12.0 https://github.com/axios/axios/security/advisories/GHSA-pmwg-cvhr-8vh7 https://github.com/axios/axios/pull/7369 https://github.com/axios/axios/security/advisories/GHSA-43fc-jf86-j433 https://github.com/axios/axios/releases/tag/v1.16.0 https://github.com/axios/axios/releases/tag/v1.8.2 https://github.com/axios/axios/security/advisories/GHSA-9fr6-4gfg-395g https://github.com/axios/axios/security/advisories/GHSA-35jp-ww65-95wh https://github.com/axios/axios/security/advisories/GHSA-3p68-rc4w-qgx5 https://github.com/axios/axios/security/advisories/GHSA-62hf-57xw-28j9 https://github.com/axios/axios/security/advisories/GHSA-m7pr-hjqh-92cm

https://github.com/axios/axios/security/advisories/GHSA-q8qp-cvcw-x6jj

https://github.com/axios/axios/security/advisories/GHSA-pmv8-rq9r-6j72

https://github.com/axios/axios/security/advisories/GHSA-777c-7fjr-54vf

https://github.com/axios/axios/commit/945435fc51467303768202250debb8d4ae892593

https://github.com/axios/axios/security/advisories/GHSA-3w6x-2g7m-8v23

https://github.com/axios/axios/releases/tag/v1.13.5

https://github.com/axios/axios/security/advisories/GHSA-3g43-6gmg-66jw

https://github.com/axios/axios/security/advisories/GHSA-6chq-wfr3-2hj9

https://github.com/axios/axios/releases/tag/v0.32.0

https://github.com/axios/axios/pull/11141

https://github.com/axios/axios/releases/tag/v0.34.0

https://github.com/axios/axios/releases/tag/v0.30.3

https://github.com/axios/axios/commit/fb8eec214ce7744b5ca787f2c3b8339b2f54b00f

https://github.com/axios/axios/commit/32fc489632377d214db55bfa4e2c48486a7d7ce2

https://github.com/axios/axios/security/advisories/GHSA-fvcv-3m26-pcqx

https://github.com/axios/axios/releases/tag/v1.20.0

https://github.com/axios/axios/security/advisories/GHSA-j5f8-grm9-p9fc

https://datatracker.ietf.org/doc/html/rfc3986#section-3.2.2

https://github.com/axios/axios/security/advisories/GHSA-445q-vr5w-6q77

https://github.com/axios/axios/commit/d7ff1409c68168d3057fc3891f911b2b92616f9e

https://github.com/advisories/GHSA-jr5f-v2jv-69x6

https://github.com/axios/axios/pull/7388

https://github.com/axios/axios/releases/tag/v1.15.0

https://github.com/axios/axios/security/advisories/GHSA-898c-q2cr-xwhg

https://github.com/axios/axios/security/advisories/GHSA-mmx7-hfxf-jppx

https://github.com/axios/axios/security/advisories/GHSA-4hjh-wcwx-xvwj

https://github.com/axios/axios/security/advisories/GHSA-vh66-26gq-q6x8

https://datatracker.ietf.org/doc/html/rfc1034#section-3.1

https://github.com/axios/axios/pull/10795

https://github.com/axios/axios/pull/10796

https://github.com/axios/axios/releases/tag/v1.18.0

https://github.com/axios/axios/pull/10794

https://github.com/axios/axios/pull/11000

https://github.com/axios/axios/pull/11001

	https://github.com/axios/axios/commit/afca61a070728e717203c2bc21e7b589b59b858b https://github.com/axios/axios/releases/tag/v0.33.0 https://github.com/axios/axios https://github.com/axios/axios/commit/1417285c69344bbcc6420a021f67dee0c6fedb2d https://github.com/axios/axios/security/advisories/GHSA-j8rh-479h-cp32 https://github.com/axios/axios/security/advisories/GHSA-5c9x-8gcm-mpgx https://github.com/axios/axios/security/advisories/GHSA-pf86-5x62-jrwf https://github.com/axios/axios/security/advisories/GHSA-w9j2-pvgh-6h63 https://github.com/axios/axios/security/advisories/GHSA-7q8q-rj6j-mhjq https://github.com/axios/axios/security/advisories/GHSA-jr5f-v2jv-69x6 https://github.com/axios/axios/commit/363185461b90b1b78845dc8a99a1f103d9b122a1 https://github.com/axios/axios/security/advisories/GHSA-jqh4-m9w3-8hp9 https://nvd.nist.gov/vuln/detail/CVE-2025-27152 https://github.com/axios/axios/pull/7011 https://github.com/axios/axios/security/advisories/GHSA-xx6v-rp6x-q39c
Instances	1
Solution	Upgrade to the latest version of the affected library.
Reference	https://owasp.org/Top10/2021/A06_2021-Vulnerable_and_Outdated_Components/
CWE Id	1395
WASC Id	
Plugin Id	10003

Medium	**CSP: Wildcard Directive**
Description	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks. Including (but not limited to) Cross Site Scripting (XSS), and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
URL	http://host.docker.internal:4021/
Node Name	http://host.docker.internal:4021/
Method	GET
Attack	
Evidence	default-src 'self'; base-uri 'self'; object-src 'none'; frame-ancestors 'none'; form-action 'self'; script-src 'self' https://maps.googleapis.com https://maps.gstatic.com https://www.gstatic.com https://www.google.com; style-src 'self' 'unsafe-inline' https://cdn.jsdelivr.net https://fonts.googleapis.com https://www.gstatic.com https://www.google.com; font-src 'self' https://cdn.jsdelivr.net https://fonts.gstatic.com; img-src 'self' data: blob: https:; connect-src 'self' https://maps.googleapis.com https://maps.gstatic.com https://places.googleapis.com https://www.gstatic.com https://www.google.com; frame-src https://www.google.com; worker-src 'self' blob:
Other Info	The following directives either allow wildcard sources (or ancestors), are not defined, or are overly broadly defined:

	img-src
URL	http://host.docker.internal:4021/signup
Node Name	http://host.docker.internal:4021/signup
Method	GET
Attack	
Evidence	default-src 'self'; base-uri 'self'; object-src 'none'; frame-ancestors 'none'; form-action 'self'; script-src 'self' https://maps.googleapis.com https://maps.gstatic.com https://www.gstatic.com https://www.google.com; style-src 'self' 'unsafe-inline' https://cdn.jsdelivr.net https://fonts.googleapis.com https://www.gstatic.com https://www.google.com; font-src 'self' https://cdn.jsdelivr.net https://fonts.gstatic.com; img-src 'self' data: blob: https:; connect-src 'self' https://maps.googleapis.com https://maps.gstatic.com https://places.googleapis.com https://www.gstatic.com https://www.google.com; frame-src https://www.google.com; worker-src 'self' blob:
Other Info	The following directives either allow wildcard sources (or ancestors), are not defined, or are overly broadly defined: img-src
Instances	2
Solution	Ensure that your web server, application server, load balancer, etc. is properly configured to set the Content-Security-Policy header.
Reference	https://www.w3.org/TR/CSP/ https://caniuse.com/#search=content+security+policy https://content-security-policy.com/ https://github.com/HtmlUnit/htmlunit-csp https://web.dev/articles/csp#resource-options
CWE Id	693
WASC Id	15
Plugin Id	10055

Medium	**CSP: style-src unsafe-inline**
Description	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks. Including (but not limited to) Cross Site Scripting (XSS), and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
URL	http://host.docker.internal:4021/
Node Name	http://host.docker.internal:4021/
Method	GET
Attack	
Evidence	default-src 'self'; base-uri 'self'; object-src 'none'; frame-ancestors 'none'; form-action 'self'; script-src 'self' https://maps.googleapis.com https://maps.gstatic.com https://www.gstatic.com https://www.google.com; style-src 'self' 'unsafe-inline' https://cdn.jsdelivr.net https://fonts.googleapis.com https://www.gstatic.com https://www.google.com; font-src 'self' https://cdn.jsdelivr.net https://fonts.gstatic.com; img-src 'self' data: blob: https:; connect-src 'self' https://maps.googleapis.com https://maps.gstatic.com https://places.googleapis.com https://www.gstatic.com https://www.google.com; frame-src https://www.google.com; worker-src 'self' blob:
Other Info	style-src includes unsafe-inline.
URL	http://host.docker.internal:4021/signin
Node	

Name	http://host.docker.internal:4021/signin
Method	GET
Attack	
Evidence	default-src 'self'; base-uri 'self'; object-src 'none'; frame-ancestors 'none'; form-action 'self'; script-src 'self' https://maps.googleapis.com https://maps.gstatic.com https://www.gstatic.com https://www.google.com; style-src 'self' 'unsafe-inline' https://cdn.jsdelivr.net https://fonts.googleapis.com https://www.gstatic.com https://www.google.com; font-src 'self' https://cdn.jsdelivr.net https://fonts.gstatic.com; img-src 'self' data: blob: https:; connect-src 'self' https://maps.googleapis.com https://maps.gstatic.com https://places.googleapis.com https://www.gstatic.com https://www.google.com; frame-src https://www.google.com; worker-src 'self' blob:
Other Info	style-src includes unsafe-inline.
URL	http://host.docker.internal:4021/signup
Node Name	http://host.docker.internal:4021/signup
Method	GET
Attack	
Evidence	default-src 'self'; base-uri 'self'; object-src 'none'; frame-ancestors 'none'; form-action 'self'; script-src 'self' https://maps.googleapis.com https://maps.gstatic.com https://www.gstatic.com https://www.google.com; style-src 'self' 'unsafe-inline' https://cdn.jsdelivr.net https://fonts.googleapis.com https://www.gstatic.com https://www.google.com; font-src 'self' https://cdn.jsdelivr.net https://fonts.gstatic.com; img-src 'self' data: blob: https:; connect-src 'self' https://maps.googleapis.com https://maps.gstatic.com https://places.googleapis.com https://www.gstatic.com https://www.google.com; frame-src https://www.google.com; worker-src 'self' blob:
Other Info	style-src includes unsafe-inline.
Instances	3
Solution	Ensure that your web server, application server, load balancer, etc. is properly configured to set the Content-Security-Policy header.
Reference	https://www.w3.org/TR/CSP/ https://caniuse.com/#search=content+security+policy https://content-security-policy.com/ https://github.com/HtmlUnit/htmlunit-csp https://web.dev/articles/csp#resource-options
CWE Id	693
WASC Id	15
Plugin Id	10055

Medium	**Vulnerable JS Library**
Description	The identified library appears to be vulnerable.
URL	http://host.docker.internal:4021/static/js/213.aa9f6aad.chunk.js
Node Name	http://host.docker.internal:4021/static/js/213.aa9f6aad.chunk.js
Method	GET
Attack	
Evidence	var a="dompurify"+(r?"#"+r:"");try{return t.createPolicy(a,{createHTML:function(e){return e},createScriptURL:function(e){return e}})}catch(i){return console.warn("TrustedTypes policy "+a+" could not be created."),null}};function ie(){var t=arguments.length>0&&void 0!==arguments[0]?arguments[0]:oe(),n=function(e){return ie(e)};if(n.version="2.5.6"
	The identified library DOMPurify, version 2.5.6 is vulnerable.

Other Info	CVE-2025-26791 CVE-2026-66010 CVE-2026-75838 CVE-2025-15599 CVE-2026-41239 CVE-2026-65899 CVE-2026-65898 CVE-2026-109345 CVE-2026-65912 CVE-2026-65901 CVE-2026-65914 CVE-2026-65903 CVE-2026-65913 CVE-2026-65902 CVE-2026-0540 CVE-2026-41240 CVE-2026-49978 CVE-2026-49458 CVE-2026-49459 https://www.vulncheck.com/advisories/dompurify-xss-via-missing-rawtext-elements-in-safeforxml https://www.vulncheck.com/advisories/dompurify-xss-via-textarea-rawtext-bypass-in-safeforxml https://github.com/cure53/DOMPurify/security/advisories/GHSA-c2j3-45gr-mqc4 https://github.com/cure53/DOMPurify/commit/d18ffcb554e0001748865da03ac75dd7829f0f02 https://github.com/cure53/DOMPurify/security/advisories/GHSA-cj63-jhhr-wcxv https://www.vulncheck.com/advisories/dompurify-xss-via-missing-rawtext-elements-in-safe-for-xml https://github.com/cure53/DOMPurify/commit/fca0a938b4261ddc9c0293a289935a9029c049f5 https://github.com/cure53/DOMPurify/security/advisories/GHSA-39q2-94rc-95cp https://github.com/cure53/DOMPurify/commit/c861f5a83fb8d90800f1680f855fee551161ac2b https://github.com/cure53/DOMPurify/security/advisories/GHSA-r47g-fvhr-h676 https://github.com/cure53/DOMPurify/security/advisories/GHSA-h7mw-gpvr-xq4m https://github.com/cure53/DOMPurify/security/advisories/GHSA-cjmm-f4jc-qw8r https://github.com/cure53/DOMPurify/security/advisories/GHSA-cmwh-pvxp-8882

	https://github.com/cure53/DOMPurify/pull/1537 https://github.com/cure53/DOMPurify/pull/1636 https://github.com/advisories/GHSA-vhxf-7vqr-mrjg https://github.com/cure53/DOMPurify/pull/1557 https://nvd.nist.gov/vuln/detail/CVE-2025-26791 https://ensy.zip/posts/dompurify-323-bypass https://nsysean.github.io/posts/dompurify-323-bypass https://github.com/cure53/DOMPurify/security/advisories/GHSA-rp9w-3fw7-7cwq https://github.com/cure53/DOMPurify/commit/b9b9d80f7e401771c2ccaef5f45def7eec8f27d7 https://github.com/cure53/DOMPurify/releases/tag/3.2.4 https://github.com/cure53/DOMPurify/releases/tag/3.3.2 https://github.com/cure53/DOMPurify/releases/tag/3.4.0 https://github.com/cure53/DOMPurify/releases/tag/3.4.16 https://github.com/cure53/DOMPurify/commit/3067f7746769 https://github.com/cure53/DOMPurify/security/advisories/GHSA-vxr8-fq34-vvx9 https://www.vulncheck.com/advisories/dompurify-xss-via-textarea-rawtext-bypass-in-safe-for-xml https://github.com/cure53/DOMPurify/security/advisories/GHSA-x4vx-rjvf-j5p4 https://github.com/cure53/DOMPurify/security/advisories/GHSA-hpcv-96wg-7vj8 https://github.com/cure53/DOMPurify/security/advisories/GHSA-h8r8-wccr-v5f2 https://github.com/cure53/DOMPurify https://github.com/cure53/DOMPurify/security/advisories/GHSA-55q2-fjhq-7xh7 https://github.com/cure53/DOMPurify/security/advisories/GHSA-6688-9rhm-gjv2 https://github.com/cure53/DOMPurify/releases/tag/3.4.12 https://github.com/cure53/DOMPurify/releases/tag/3.4.13 https://github.com/cure53/DOMPurify/commit/a9ca1e537422319a557a9a2aa61f003b23b4a197 https://github.com/cure53/DOMPurify/security/advisories/GHSA-crv5-9vww-q3g8 https://github.com/cure53/DOMPurify/security/advisories/GHSA-76mc-f452-cxcm
Instances	1
Solution	Upgrade to the latest version of the affected library.
Reference	https://owasp.org/Top10/2021/A06_2021-Vulnerable_and_Outdated_Components/
CWE Id	1395
WASC Id	
Plugin Id	10003

Low	**Timestamp Disclosure - Unix**

Description	A timestamp was disclosed by the application/web server. - Unix
URL	http://host.docker.internal:4021/static/js/239.fcaddd2b.chunk.js
Node Name	http://host.docker.internal:4021/static/js/239.fcaddd2b.chunk.js
Method	GET
Attack	
Evidence	1604231423
Other Info	1604231423, which evaluates to: 2020-11-01 11:50:23.
URL	http://host.docker.internal:4021/static/js/239.fcaddd2b.chunk.js
Node Name	http://host.docker.internal:4021/static/js/239.fcaddd2b.chunk.js
Method	GET
Attack	
Evidence	1687547391
Other Info	1687547391, which evaluates to: 2023-06-23 19:09:51.
URL	http://host.docker.internal:4021/static/js/239.fcaddd2b.chunk.js
Node Name	http://host.docker.internal:4021/static/js/239.fcaddd2b.chunk.js
Method	GET
Attack	
Evidence	1768516095
Other Info	1768516095, which evaluates to: 2026-01-15 22:28:15.
URL	http://host.docker.internal:4021/static/js/239.fcaddd2b.chunk.js
Node Name	http://host.docker.internal:4021/static/js/239.fcaddd2b.chunk.js
Method	GET
Attack	
Evidence	2005441023
Other Info	2005441023, which evaluates to: 2033-07-20 02:57:03.
URL	http://host.docker.internal:4021/static/js/239.fcaddd2b.chunk.js
Node Name	http://host.docker.internal:4021/static/js/239.fcaddd2b.chunk.js
Method	GET
Attack	
Evidence	2096890111
Other Info	2096890111, which evaluates to: 2036-06-12 13:28:31.
Instances	Systemic
Solution	Manually confirm that the timestamp data is not sensitive, and that the data cannot be aggregated to disclose exploitable patterns.
Reference	https://cwe.mitre.org/data/definitions/200.html
CWE Id	497

WASC Id	13
Plugin Id	10096

Informational	**Modern Web Application**
Description	The application appears to be a modern web application. If you need to explore it automatically then the Client Spider may well be more effective than the standard one.
URL	http://host.docker.internal:4021/
Node Name	http://host.docker.internal:4021/
Method	GET
Attack	
Evidence	<script defer="defer" src="/static/js/main.ba8f17b4.js"></script>
Other Info	No links have been found while there are scripts, which is an indication that this is a modern web application.
URL	http://host.docker.internal:4021/signin
Node Name	http://host.docker.internal:4021/signin
Method	GET
Attack	
Evidence	<script defer="defer" src="/static/js/main.ba8f17b4.js"></script>
Other Info	No links have been found while there are scripts, which is an indication that this is a modern web application.
URL	http://host.docker.internal:4021/signup
Node Name	http://host.docker.internal:4021/signup
Method	GET
Attack	
Evidence	<script defer="defer" src="/static/js/main.ba8f17b4.js"></script>
Other Info	No links have been found while there are scripts, which is an indication that this is a modern web application.
Instances	3
Solution	This is an informational alert and so no changes are required.
Reference	
CWE Id	
WASC Id	
Plugin Id	10109